

docs/modules/user-management.md

User management модули - SPEC (Хавфсизлик, NAVBAT 11)

Ҳолат - каноник харита: AppUser/UserService/lockout/createdBy - ШУ файл (амалга оширилган, roadmap «Хавфсизлик»); роль/permission модели - user-roles.md (092: 8 роль + соҳа permission); профиль UI/2FA/Telegram - user-profile.md. Манба: карта SEC-004 (ҳозир done/archived/) + SEC-002 lockout + roadmap «Хавфсизлик» бўлими.

Эталон: QBO «Manage users» - фойдаланувчилар рўйхати, роль бериш, нофаол қилиш (ўчириш йўқ). Email- invite оқими QBO'да бор, бизда ЙЎҚ (email инфраструктураси йўқ) - атайлаб фарқ эмас, кейинга қолдирилган соддалаштириш.

Мақсад

Ҳозир тизимда биттагина bootstrap admin бор (AdminUserInitializer , фақат app_user жадвали бўш бўлганда яратилади) ва уни иловадан бошқариб бўлмайди: парол алмаштириш, янги фойдаланувчи қўшиш, роль бериш экрани йўқ. Бу молия тизими учун хавф (SEC-004):

- 1. Singleton admin - парол йўқолса тизимга ҳеч ким кира олмайди (қутқариш фақат қўлда DB UPDATE).
- 2. Паролни иловадан алмаштириб бўлмайди.
- 3. Кўп фойдаланувчи бўлганда «ким киритди» аудит изи йўқ - кечиктирилса миграция оғирлашади.
- 4. Роллар мавжуд (жорий: 8 роль - user-roles.md), лекин бошқарув интерфейси йўқ.

Модул шуларни ёпади: /users CRUD (USERS соҳаси), парол алмаштириш оқимлари, login lockout (SEC-002) ва createdBy аудит майдони режаси.

Entity

AppUser (app_user) - мавжуд, кенгаяди

Мавжуд майдонлар ўзгармайди (username, password_hash, display_name, role, active - security/domain/AppUser.java). Янги майдонлар:

Майдон	Тип	Изоҳ
failed_attempts	int, default 0	Кетма-кет муваффақиятсиз login уринишлари сони; муваффақиятли киришда нолланади
locked_until	timestamp tz nullable	Шу пайтгача login тақиқ (BR-USR-009); NULL - қулф йўқ. UTC (темир қоида №12)

Changeset: db/changeLog/ даги навбатдаги бўш рақам (список ёзилган пайтда 026; параллел ишлагани учун код пайтида қайта текширилади) - ALTER TABLE app_user ADD COLUMN ... иккала майдон.

Эслатмалар: - Ўчириш ЙЎҚ - фақат active=false (тарих ва createdBy излари сақланади). Бу CoA/Contact'даги мавжуд қонданнинг айнан ўзи. - username яратилгандан кейин ЎЗГАРМАЙДИ (BR-USR-003) - аудит изи стабил бўлиши учун. Сақлашда lower-case'га нормализация қилинади. - Парол ҲЕЧ ҚАЧОН очиқ кўринишда сақланмайди/логга ёзилмайди - фақат bcrypt hash (мавжуд PasswordEncoder).

UserRole

092 дан бери 8 роль (`security/domain/UserRole.java`) - рўйхат, рухсат матрицаси ва миграция тафсилоти `user-roles.md` да (бу бўлимдаги эски 3-роль модели 092 гача эди).

Service - public API

Жойлашуви: `security.service.UserService` (янги). Бошқа модуллар фақат шу орқали мурожаат қилади (темир қоида №6).

```
public class UserService {
    List<AppUser> all; // рўйхат, тартиб: username
    AppUser get(UUID id); // NOT_FOUND билан
    AppUser create(String username, String displayName,
        UserRole role, String rawPassword); // BR-USR-001/002/004/005
    AppUser update(UUID id, String username, String displayName,
        UserRole role, boolean active); // BR-USR-003/004/007/008
        // username фақат BR-USR-003 текшируви учун қабул
        // қилинади (ўзгартирилмайди - tampered POST'га қарши)
    void changePassword(UUID id, String newRawPassword); // USERS EDIT ҳар қимға - BR-USR-005
    void changeOwnPassword(String oldRawPassword,
        String newRawPassword); // жорий user - BR-USR-005/006
    Map<UUID, String> namesById; // createdBy кўрсатиш учун
        // (экран қатлами, contactNames паттерни)
}
```

Logout мантиғи controller'да ЭМАС, Spring Security қатламида (SEC-002 арбитр талаби):

- `JpaUserDetailsService` (мавжуд): `locked_until > now` бўлса `accountNonLocked=false` қайтаради → `LockedException`.
- Янги `LoginAttemptListener` (`security.service`): `AuthenticationFailureBadCredentialsEvent` 'да мавжуд `user`'нинг `failed_attempts++`; 5 га етганда `locked_until = now + 15 дақиқа`. `AuthenticationSuccessEvent` 'да иккала майдон нолланади.
- Онгли қабул қилинган хавф: қулф хабари `username` мавжудлигини билвосита ошкор қилади (enumeration). Internal MVP учун қабул қилинади; deployment ташқи бўлса SEC-002'нинг IP-даражали чекловлари билан бирга қайта кўрилади.

Валидация - BR каталоги таклифи (BR-USR-*)

`BusinessRule` enum'га ва `docs/business-rules.md`'га БИРГА қўшилади (каталог қоидаси: аввал каталог, кейин код). HTTP: дубликат 409, қолгани 400.

Код	Қоида
BR- USR- 001	username шарт: бўш эмас, 3-50 белги, фақат <code>a-z 0-9 . _ -</code> (lower-case нормализация)
BR- USR- 002	username unique (409)
BR- USR- 003	username ўзгартирилмайди - update'да келган қиймат мавжудидан фарқ қилса хато
BR- USR- 004	displayName бўш эмас
BR- USR- 005	Парол сиёсати: камида 8 белги (яратишда ва ҳар алмаштиришда)
BR- USR- 006	Ўз паролини алмаштиришда эски парол тўғри бўлиши шарт (bcrypt текшируви)
BR- USR- 007	Амал натижасида тизимда камида битта ФАОЛ SUPER_ADMIN қолиши шарт - охириги фаол super admin'ни нофаол қилиш ёки ролини пасайтириш тақиқ (роль тизимига: ADMIN)
BR- USR- 008	Фойдаланувчи ЎЗИНИ нофаол қила олмайди (бошқа super admin бор бўлса ҳам - сессия ўртасида ўзини қулфлаш чалкашлиги олдини олади)
BR- USR- 009	Login logout: 5 кетма-кет хато уриниш → 15 дақиқа қулф; муддат ўтгач ёки муваффақиятли киришда счётичк нолланади. Кодда BusinessException эмас - Spring Security <code>LockedException</code> (login?locked хабари); каталогда ҳужжат учун туради
BR- USR- 010	Нофаол фойдаланувчи тизимга кира олмайди (мавжуд хулқ - <code>JpaUserDetailsService</code> disabled флаги; шу код остида ҳужжатланади)

БР оиласининг КАНОНИК манбаи - docs/business-rules.md (BR-USR бўлими): у ерда оила BR-USR-015 гача давом этади, жумладан BR-USR-011 (роль тайинлаш - фақат USERS EDIT) ва BR-USR-012 (ўз SUPER_ADMIN ролини пасайтириш тақиқ) - тафсилот user-roles.md.

SecurityConfig ўзгаришлари

- /users URL'лари соҳа қоидаси билан: URL → соҳа харитаси (UrlPermissionMap, USERS соҳаси) ва `hasAuthority` permission - рольга ЭМАС (user-roles.md).
- `.requestMatchers(HttpMethod.POST, "/profile/password").authenticated` - умумий POST-catchall (камида битта соҳа EDIT талаби)дан ОЛДИН туради (logout истисноси паттерни): view-only роллар ҳам ўз паролини алмаштира олиши шарт.
- `AdminUserInitializer` ўзгармайди (bootstrap фақат бўш жадвалда).

createdBy аудит майдони режаси (SEC-004 §7)

Мақсад: ҳар ёзувчи ҳаракатда «ким» изи. Кечиктириш миграцияни оғирлаштиради - шу туртки ичида қилинади.

- **Қаеpra:** BaseEntity 'га @CreatedBy UUID createdBy (nullable, updatable=false). Битта жойда - БАРЧА entity'лар қамралади (ҳужжатлар ҳам, каталоглар ҳам). JPA auditing аллақачон фаол (AuditingEntityListener , @CreateDate ишлапти) - фақат AuditorAware<UUID> bean етишмаяпти.
- **AuditorAware:** security модулида (SecurityContext → username → AppUser id, кэшсиз оддий lookup). BaseEntity (shared) security'га боғланмайди - майдон тоза UUID.
- **FK йўқ:** created_by устунига app_user FK қўйилмайди - JournalEntryLine.contactId dimension паттерни (модул мустақиллиги); app_user ўчирилмагани (фақат active=false) учун из ҳеч қачон «осилиб» қолмайди.
- **Changeset:** navbatdagi бўш рақам (спец пайтида 027, 026'ни app_user олади) - БАРЧА мавжуд жадвалларга ADD COLUMN created_by uuid NULL (ddl-auto=validate учун тўлиқ рўйхат шарт: app_user'дан тортиб bank_transaction'гача, changeset ёзилаётганда жадваллар рўйхати db/changelog/ дан терилади).
- **Эски ёзувлар default'и:** NULL - «миграциядан олдинги ёзув». Сохта атрибуция қилинмайди (bootstrap admin'га ёзиб қўйиш алдамчи из қолдиради). Экранда NULL «-» кўринади.
- **Тизим ҳаракатлари:** scheduler (ЦБ курс импорти) ва bootstrap каби auth контекстисиз ёзувларда NULL қолади - AuditorAware бўш Optional қайтаради.
- **Кўрсатиш:** бу турткида ФАҚАТ майдон тўлдирилади; ҳужжат view'ларига «Киритди: ...» қатори (UserService.namesByld орқали) алоҳида кичик UI туртки бўлади.

Экранлар (JTE, i18n УЧАЛА тил, docs/ui-style-guide.md қолиплари)

/users - рўйхат (USERS соҳаси)

- Sidebar: «Созламалар» группасига «Фойдаланувчилар» ҳаволаси (соҳа кўринишига қараб филтрланади - Perms, 092).
- layout/main.jte ; жадвал .table-wrap ичида: Логин, Ном, Роль (i18n: user.role.SUPER_ADMIN ва ҳ.к.), Ҳолат (фаол/нофаол - accounts услубидаги яшил/кулранг), Қулф (locked_until келажакда бўлса «қулфланган HH:mm гача» - kulrang матн).
- Row-click: қатор → таҳрир формаси (каталог қоидаси, T0 механизми, data-href); охириги устунда Edit ҳаволаси ҳам қолади (item/list паттерни).
- Тепада «Янги фойдаланувчи» .btn (bills сарлавҳа қолипи).
- Flash message/error блоклари стандарт жойида.

/users/new ва /users/{id}/edit - форма (USERS соҳаси)

- Содда карта форма (max-width:560px grid - adjustmentForm қолипи, layout/main ичида; full-screen form.jte ШАРТ ЭМАС - майдон оз).
- Майдонлар: username (яратишда input + формат ҳинти; таҳрирда фақат ўқиладиган матн - BR-USR-003), displayName, role select (8 роль - user-roles.md, i18n), active checkbox (фақат таҳрирда).
- Яратишда парол: type="password" иккита майдон (парол + такрор, мослиги client+server текширилади), autocomplete="new-password". Парол генерацияси/мажбурий алмаштириш флаги - «Кейин» бўлимида.
- CSRF hidden ҳар формада; хато displayMessage билан форма устида.
- Таҳрир саҳифасида АЛОҲИДА карта: «Паролни алмаштириш» (янги парол + такрор, POST /users/{id}/password) - асосий формадан ажратилган, тасодифан бирга submit бўлмайди.

/profile/password - ўз парolini алмаштириш (ҳамма роллар)

- Sidebar footer'да (logout тугмаси устида) «Паролни алмаштириш» ҳаволаси - ҳар киши ўзиникига киради, `{id}` йўқ (жорий сессиядан).
- Майдонлар: эски парол, янги парол, такрор (BR-USR-005/006).
- Муваффақиятда flash + ўша саҳифада қолади (сессия узилмайди - Spring Security сессияни сақлайди).

Login саҳифаси

- Мавжуд `login.jte` га `?locked` параметри учун битта хабар қўшилади: «Уринишлар кўп бўлди - 15 дақиқадан кейин қайта уриниб кўринг» (i18n, учала тил). `?error` хабари ўзгармайди (enumeration бермайди).

Тестлар (мажбурий рўйхат)

- create: BR-USR-001 (формат: қисқа, тақиқланган белги, upper-case нормализацияси), BR-USR-002 (дубликат 409), BR-USR-005 (қисқа парол); муваффақиятли create'да парол hash bcrypt ва очик парол ҳеч қаерда сақланмаган.
- update: displayName/role/active янгиланади; BR-USR-003 (username ўзгартиришга уриниш); BR-USR-007 (охирги фаол SUPER_ADMIN'ни demote ҲАМ deactivate ҲАМ тақиқ; иккита фаол super admin бўлса бирини пасайтириш OK); BR-USR-008 (ўзини нофаол қилиш).
- changePassword (admin): янги hash билан эски парол ишламайди, янгиси ишлайди (PasswordEncoder.matches).
- changeOwnPassword: BR-USR-006 (эски парол хато), муваффақиятли оқим.
- logout: 5 хато уриниш → 6-уриниш LockedException (тўғри парол билан ҳам); locked_until ўтгач кириш OK ва счётчик нолланган; 4 хатодан кейин муваффақиятли кириш счётчикни нолласин (SEC-002 кутилмаси).
- BR-USR-010: active=false user login қила олмайди (мавжуд хулқ regression тести).
- createdBy: auth контекстида сақланган entity'да жорий user id; контекстсиз (scheduler симуляцияси) NULL.
- namesById: рўйхат тўғри тар қайтаради.

Кейин (бу турткига КИРМАЙДИ)

- Парол генерацияси / биринчи киришда мажбурий алмаштириш флаги.
- Email invite / парол reset ҳаволаси (email инфраструктураси йўқ).
- 2FA, сессияларни бошқариш (фаол сессияларни кўриш/узиш).
- Хужжат view'ларида «Киритди: ...» қатори (createdBy кўрсатиш UI'си).
- AuditLog жадвали (roadmap «Кейинги навбат» - createdBy унинг ўрнини босмайди, фақат биринчи қадами).